

E-BOOK GRATUITO · LGPD NA SAÚDE

Guia da LGPD no Ambiente Hospitalar

Os 10 passos essenciais para adequar hospitais e clínicas à Lei Geral de Proteção de Dados e proteger os dados sensíveis dos pacientes.

Denis Carvalho dos Santos Vieira

Advogado · OAB/GO 53.904 · Especialista em Direito Médico e da Saúde
www.lgpdesaude.com.br

Por que este guia existe

Na saúde, proteger dados deixou de ser uma questão de tecnologia — é, antes de tudo, uma questão de confiança e de responsabilidade jurídica.

Hospitais, clínicas, laboratórios e operadoras tratam diariamente os dados mais sensíveis que existem: diagnósticos, prontuários, exames, histórico de doenças. A Lei Geral de Proteção de Dados (Lei nº 13.709/2018) classifica essas informações como **dados pessoais sensíveis** (art. 11), submetendo-as ao regime mais rígido da lei.

O descumprimento expõe a instituição a multas de até 2% do faturamento (limitadas a R\$ 50 milhões por infração), à obrigação de comunicar incidentes à ANPD e aos pacientes, e a ações indenizatórias — sem falar no dano reputacional, muitas vezes o mais caro de todos.

A boa notícia: a adequação pode ser feita por etapas, no ritmo da instituição. Este guia mostra os 10 passos que mais reduzem risco e constroem uma cultura sólida de proteção de dados.

Use-o como um mapa. Ele não substitui uma orientação jurídica individualizada, mas vai ajudar a enxergar onde a sua instituição está exposta.

Os 10 passos essenciais

1 Diagnóstico (gap analysis)

Avalie o estágio atual da instituição: como os dados entram, circulam, são guardados e descartados, e onde estão os maiores riscos. Sem esse retrato, qualquer medida é no escuro.

2 Mapeamento de dados (data mapping)

Faça o inventário dos fluxos de dados de pacientes e colaboradores, registrando as operações de tratamento. É a base de todo o programa de privacidade.

3 Definição das bases legais

Cada tratamento precisa de um fundamento legal. Para a assistência, aplica-se a tutela da saúde; para marketing e pesquisa, geralmente é necessário consentimento específico.

4 Políticas e avisos de privacidade

Política de privacidade, aviso ao paciente, termos de consentimento e política de retenção, redigidos para a realidade da instituição — não modelos genéricos.

5 Controle de acesso e prontuário

Perfis de acesso por função, trilha de auditoria e regras claras de uso do prontuário eletrônico. Ninguém deve ver mais do que precisa para o seu trabalho.

6 Segurança da informação

Criptografia, autenticação forte, backups testados e segregação de ambientes — medidas proporcionais à sensibilidade dos dados de saúde.

7 Contratos com fornecedores (operadores)

Sistemas, nuvem, laboratórios e empresas de cobrança que acessam dados precisam de cláusulas de proteção de dados e definição de responsabilidades.

8 Regras de uso do WhatsApp

Mensagens com exames e laudos são um dos maiores pontos de risco. Defina o que pode e o que não pode trafegar, e por quais canais.

9 Plano de resposta a incidentes

Tenha papéis definidos, fluxo de comunicação e modelos prontos para agir em caso de vazamento — incluindo a comunicação à ANPD e aos titulares no prazo.

10 Encarregado (DPO), treinamento e governança

Indique um encarregado, treine todas as equipes e estabeleça revisões periódicas. Conformidade é processo contínuo, não evento único.

Regra de ouro: conformidade precisa ser demonstrável. Documente cada decisão — é isso que protege a instituição em uma fiscalização e constrói a confiança dos pacientes.

PRÓXIMO PASSO

Vamos adequar a sua instituição?

Se você quer fazer o diagnóstico, estruturar a documentação ou contar com um encarregado externo especializado em saúde, fale diretamente comigo. A primeira orientação é sem compromisso.

WHATSAPP

(62) 99258-6422

TELEFONE

(64) 99945-2151

E-MAIL

contato@deniscarvalhoadvocacia.com.br

SITE

www.lgpdesaude.com.br

Denis Carvalho dos Santos Vieira — OAB/GO 53.904. Material de caráter informativo, em conformidade com o Provimento nº 205/2021 do CFOAB. Não constitui consulta jurídica nem promessa de resultado.